Vulnerability Assessment Report

Public Website : demo.testfire.net

Altoro Mutual demo banking site (built for security testing)

Prepared by: Sukh Ram Godara

Future Interns - Cyber Security Internship - Task 1

Date: 3 November 2026

Method: read-only, passive analysis

FUTURE INTERNS

1. Scope and Method

What was tested, how it was tested, and what was deliberately not done.

Target	http://demo.testfire.net (IP 65.61.137.117 at time of scan)
About	Altoro Mutual demo banking site, published publicly for security testing
Date	3 November 2026
Approach	Read-only, passive analysis. No credentials used, no data modified.

In scope

- Public-facing pages of demo.testfire.net only
- Passive analysis of pages browsed manually
- HTTP response header and cookie review
- Basic port and service detection

Not performed (out of scope)

- Login bypass, exploitation, brute force, denial of service
- ZAP active scan or spider, form payload injection (SQLi, XSS)
- Testing of any other host or domain

Tools used

- **OWASP ZAP 2.17.0** (Safe Mode, passive scan through manual browsing)
- **Nmap 7.99** (command: nmap -sV -T3 demo.testfire.net)
- **Firefox Developer Tools** (response headers, cookies)
- Kali Linux (virtual machine) and Canva (report design)

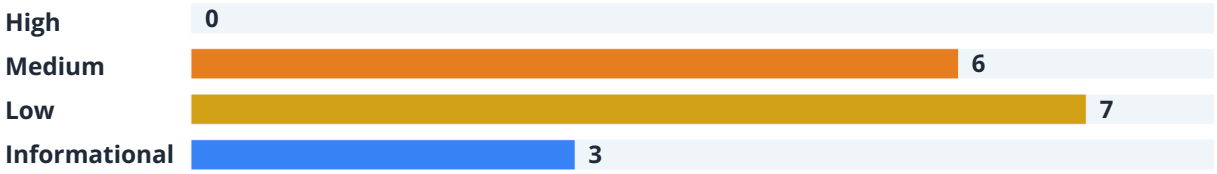
Third-party hosts that appeared during browsing (github.com, swagger.io) were outside scope and were not assessed.

2. Executive Summary

The site has no High-risk issues from passive analysis. The main weaknesses are the use of unencrypted HTTP, missing browser security headers, and missing protection on forms.

0	6	7	3
HIGH	MEDIUM	LOW	INFO

16 findings in total: 12 raised by OWASP ZAP plus 4 manual observations (M-01, M-06, L-04, L-07).



What is working well

- The session cookie has the **HttpOnly** flag, so page scripts cannot read it.
- Only **3 ports are open** (80, 443, 8080), the other 997 scanned ports were filtered, so the attack surface is small.

What needs attention first

- The site is available over **unencrypted HTTP**, so data can be read or altered in transit.
- The **HTTPS certificate has expired**, so browsers show a full-page security warning.
- Several **browser security headers are missing** (CSP, anti-clickjacking, content-type protection).
- Forms have **no CSRF protection**.

3. Medium Risk Findings

ID	Finding	What it means (plain language)	Recommended fix
M-01	**Site served over unencrypted HTTP (port 80)**	Data sent to the site, such as login or form details, can be read or altered while in transit.	Redirect all HTTP traffic to HTTPS and enable HSTS.
M-02	**Anti-CSRF tokens missing (3 forms, e.g. feedback.jsp)**	Another website could make a user submit a form without their knowledge.	Add a unique anti-CSRF token to every form.
M-03	**Content-Security-Policy header not set**	The browser is not told which scripts are trusted, making fake scripts easier to run.	Add a Content-Security-Policy header.
M-04	**Anti-clickjacking header missing**	Another site could hide this page inside its own and trick users into clicking.	Set X-Frame-Options or CSP frame-ancestors.
M-05	**Sub Resource Integrity attribute missing**	If an external file is tampered with, this site would load the altered file.	Add integrity attributes to external scripts and styles.
M-06	**HTTPS certificate expired (port 443)**	Browsers show a full-page security warning, visitors cannot trust the site, and users get used to clicking through warnings.	Renew the certificate and set up automatic renewal.

M-01 and M-06 are manual observations (Nmap and browser). M-02 to M-05 were raised by OWASP ZAP; M-03 and M-04 were also confirmed in the response headers using browser Developer Tools.

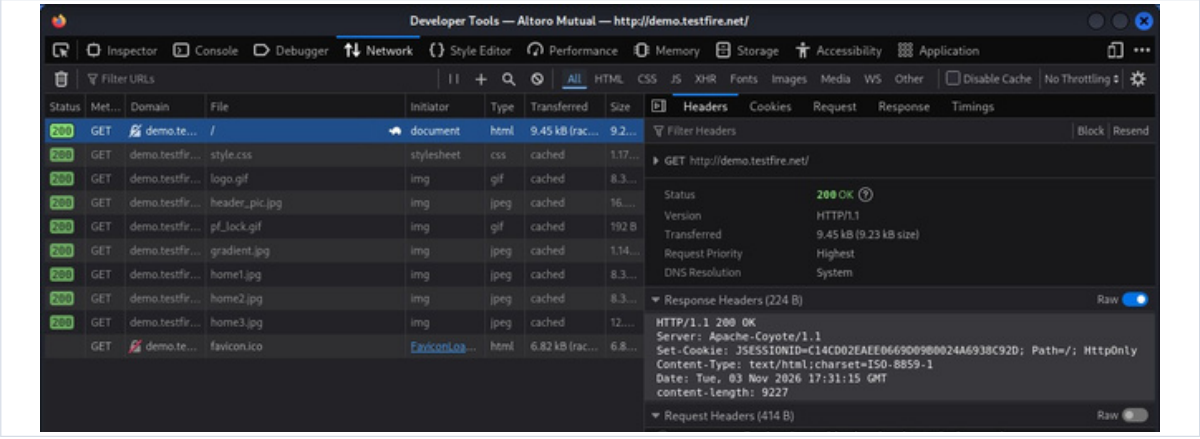


Figure 1: Response headers in Firefox DevTools. No security headers present; Server shows Apache-Coyote/1.1 (M-03, M-04, L-01, L-02)

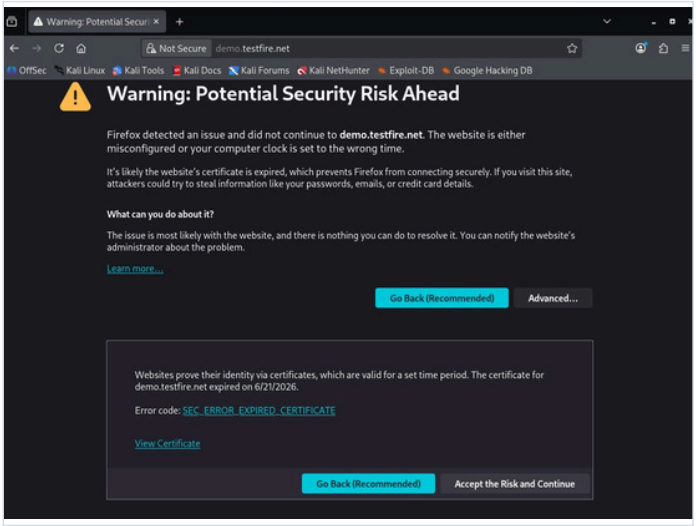


Figure 2: Expired HTTPS certificate warning in Firefox (M-06)

Evidence for Medium findings

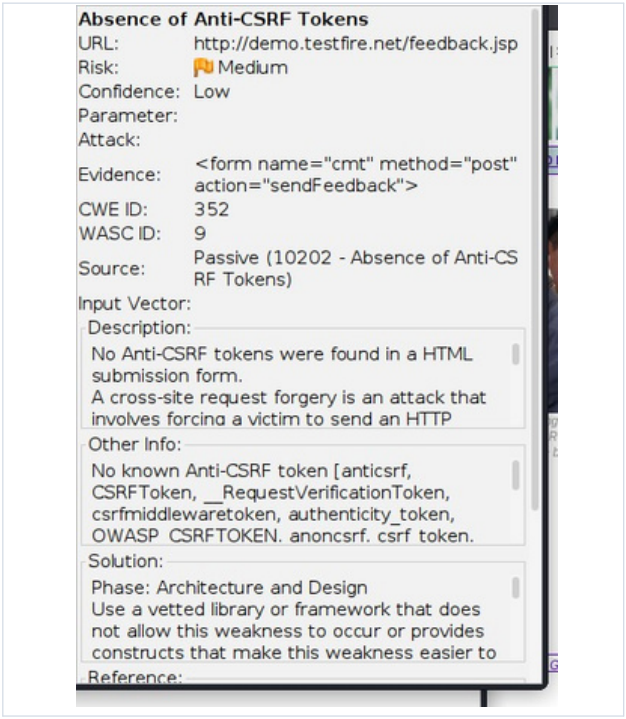


Figure 3: ZAP alert, Absence of Anti-CSRF Tokens on feedback.jsp (M-02)

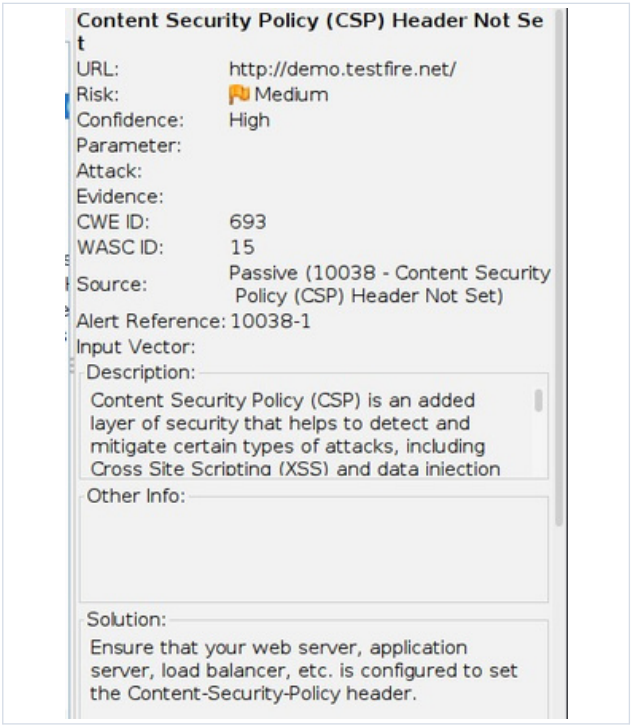


Figure 4: ZAP alert, Content-Security-Policy header not set (M-03)

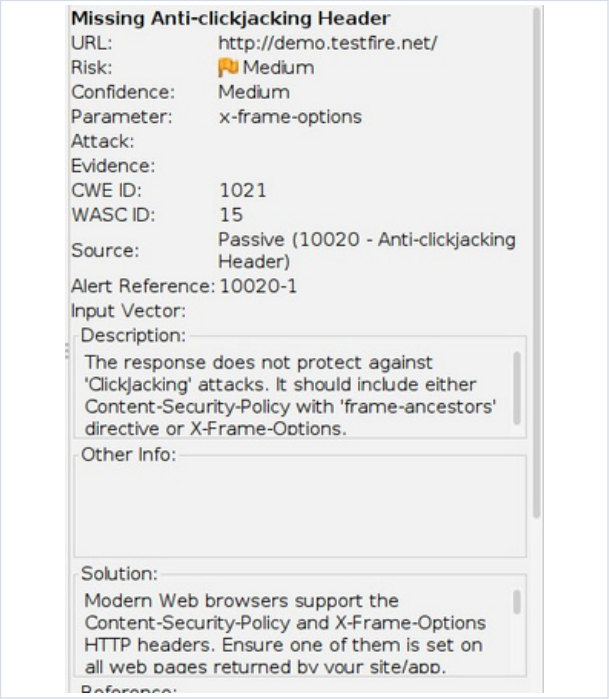


Figure 5: ZAP alert, missing anti-clickjacking header (M-04)

4. Low Risk Findings

ID	Finding	What it means (plain language)	Recommended fix
L-01	**Server technology and version exposed (Apache-Coyote/1.1)**	Tells attackers what software runs, helping them look for known weaknesses.	Hide the banner and keep Tomcat updated. Exact version should be verified.
L-02	**X-Content-Type-Options header missing**	The browser may wrongly guess a file type.	Add X-Content-Type-Options: nosniff.
L-03	**Session cookie without SameSite attribute**	The cookie is sent along with requests coming from other sites.	Set SameSite to Lax or Strict.
L-04	**Session cookie without Secure flag**	The cookie can travel over unencrypted HTTP.	Add the Secure flag.
L-05	**Debug error messages visible**	Errors reveal internal technical detail.	Show a simple generic error page in production.
L-06	**Cross-domain JavaScript source file inclusion**	The site runs JavaScript from outside servers, if one is compromised, so is the site.	Use trusted sources only, or host files locally.
L-07	**Port 8080 open (alternate web port)**	Extra web ports often hold test or admin pages.	Close it if not needed, or restrict it with a firewall.

L-04 and L-07 are manual observations (DevTools and Nmap). L-01 to L-03, L-05 and L-06 were raised by ZAP; L-01, L-02 and L-03 were also confirmed in DevTools.

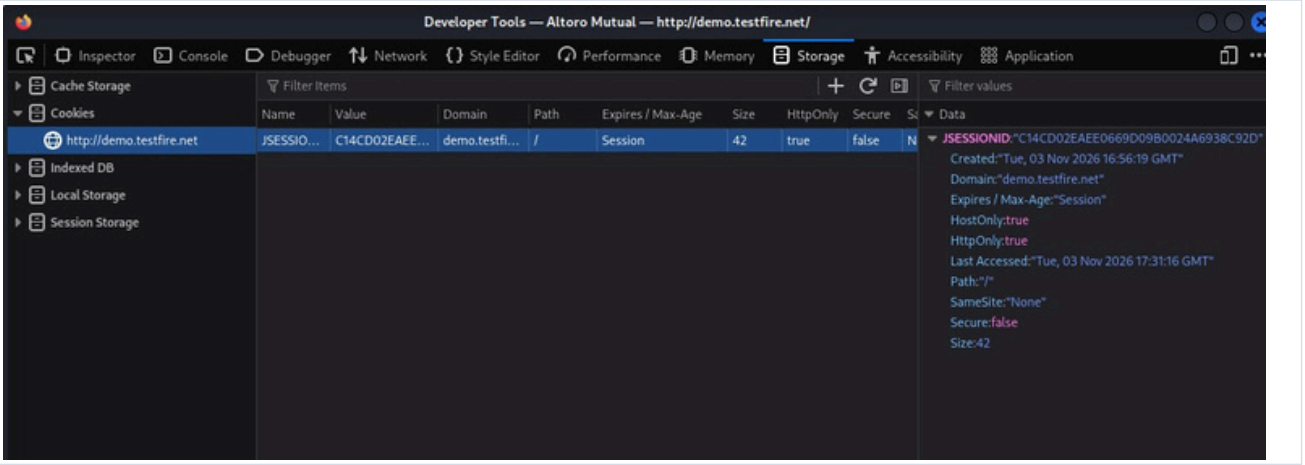


Figure 6: Session cookie in DevTools: HttpOnly true, Secure false, SameSite shown as None (L-03, L-04)

Evidence for Low findings

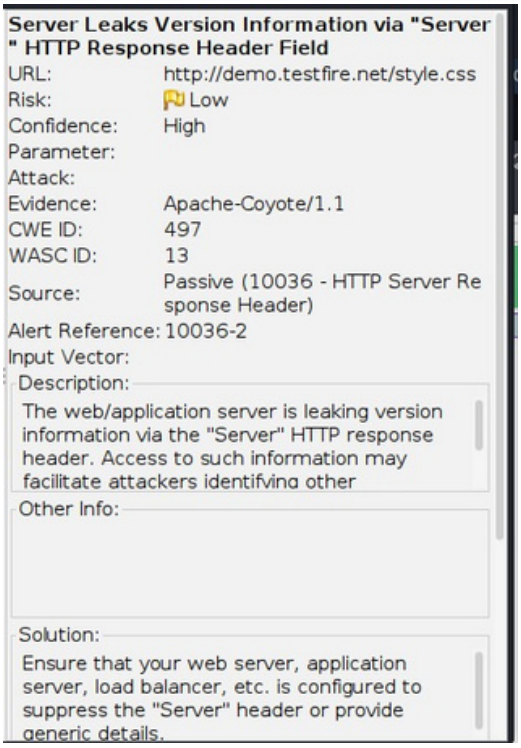


Figure 7: ZAP alert, Server header leaks version information (L-01)

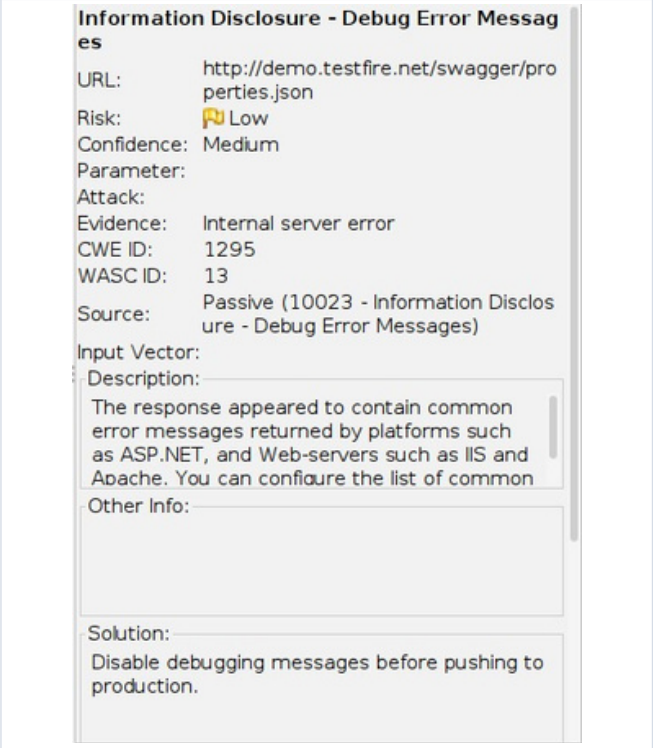


Figure 8: ZAP alert, debug error message on swagger/properties.json (L-05)

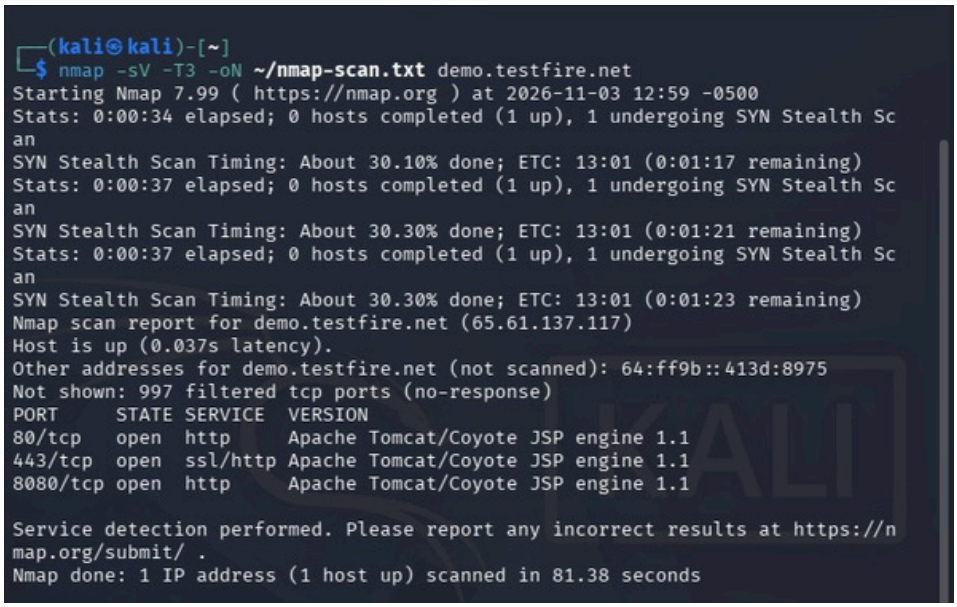


Figure 9: Nmap scan result, ports 80, 443 and 8080 open, 997 filtered (L-01, L-07)

5. Informational Observations

ID	Observation
I-01	Suspicious developer comments found in page source
I-02	Modern web application detected
I-03	Session management response identified

Evidence summary

Check	Result
Response headers (DevTools)	Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security and Referrer-Policy were not present. The Server header showed Apache-Coyote/1.1.
Session cookie (DevTools)	JSESSIONID set with HttpOnly. No Secure flag and no SameSite attribute.
Port scan (Nmap)	Ports 80, 443 and 8080 open, all running Apache Tomcat/Coyote JSP engine 1.1. 997 ports filtered.
HTTPS certificate (Firefox)	Certificate for demo.testfire.net expired on 6/21/2026 (error SEC_ERROR_EXPIRED_CERTIFICATE).
Passive scan (ZAP)	12 alerts on demo.testfire.net : 4 Medium, 5 Low, 3 Informational, 0 High.

Screenshots and the full ZAP report are stored in the evidence folder of the GitHub repository.

6. Fix Priority

Recommended order of work for the website owner.

1.	**Fix HTTPS: renew the expired certificate and redirect HTTP to HTTPS** Covers: M-01, M-06, L-04 Protects all data in transit. Also add the Secure flag on cookies.
2.	**Add security headers together in the server configuration** Covers: M-03, M-04, L-02 One configuration change closes several findings at once.
3.	**Add CSRF protection to all forms** Covers: M-02 Stops other sites from submitting forms on behalf of users.
4.	**Remaining cleanup** Covers: M-05, L-01, L-03, L-05, L-06, L-07 SRI attributes, hide server banner, cookie SameSite, generic error pages, trusted script sources, close port 8080 if unused.

7. Conclusion

The passive review of demo.testfire.net found no High-risk issues, but it did find several weaknesses that a real business website should fix: unencrypted HTTP, an expired HTTPS certificate, missing security headers, missing form protection and cookie settings that can be tightened. Most of these can be resolved with server configuration changes rather than rewriting the application. The site is a purpose-built demo, so these results are expected and are used here to practise professional reporting.

Notes

- Risk ratings are the assessor's classification.
- M-01, M-06, L-04 and L-07 are manual observations and were not raised by ZAP.
- All testing was read-only and passive. No exploitation was attempted.
- Evidence, scope and findings files: public GitHub repository FUTURE_CS_01.